

Security+ 2.2 · Common Threat Vectors

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.2 — Common Threat Vectors (17:14) · [vídeo original ↗](#) · [YouTube ↗](#)

Vetores = como o ataque chega: email/SMS/voz, imagem, arquivo, chamada, credencial default nunca trocada, software infectado, USB baiting, malvertising (anúncio malicioso), credential stuffing (reuso de senha vazada), insider, rede remota, IoT/nuvem física.

💡 Highlights que a prova cobra

- Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA
- Malvertising: anúncio malicioso em site legítimo
- Credential stuffing = USAR senha vazada em outros sites (vs brute force)

🎯 Dicas de prova

- 'reuses leaked credentials across multiple sites' = credential stuffing
- 'malicious advertisement on a legitimate website' = malvertising

Cenário clássico: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?

- A) Firewall mal configurado
- B) Phishing + VPN sem MFA / credencial vazada
- C) Cabo de rede exposto
- D) Falta de antivírus

2. Atacante testa senhas VAZADAS de um site em VÁRIOS outros sites (reúso de senha):

- A)** Credential stuffing
- B)** Força bruta pura
- C)** Rainbow table
- D)** Vishing

3. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

4. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Malvertising: anúncio malicioso em site legítimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Malvertising: anúncio malicioso em site legítimo...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Credential stuffing = USAR senha vazada em outros sites (vs brute force)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Credential stuffing = USAR senha vazada em outros sites (vs brute force)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'reuses leaked credentials across multiple sites' = credential stuffing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'reuses leaked credentials across multiple sites' = credential stuffing...

8. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'malicious advertisement on a legitimate website' = malvertising'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'malicious advertisement on a legitimate website' = malvertising...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras c...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Common Threat Vectors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) B — Phishing + VPN sem MFA / credencial vazada. A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1.

2) A — Credential stuffing. Credential stuffing = reusar credenciais vazadas em outros serviços. Força bruta testa combinações; dictionary usa lista de palavras comuns.

3) A — Ataque de cadeia de suprimentos. Supply chain attack compromete um elo confiável (fornecedor) pra alcançar muitos alvos de uma vez.

4) B — Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, US. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA. As demais alternativas configuram violaç

5) C — Implementar a solução correspondente: Malvertising: anúncio malicioso em site le. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Malvertising: anúncio malicioso em site legítimo. As demais alternativas configuram violações graves de conform

6) A — Implementar a solução correspondente: Credential stuffing = USAR senha vazada em. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Credential stuffing = USAR senha vazada em outros sites (vs brute force). As demais alternativas configuram vio

7) D — Implementar a solução correspondente: 'reuses leaked credentials across multiple. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): 'reuses leaked credentials across multiple sites' = credential stuffing. As demais alternativas configuram viol

8) A — Implementar a solução correspondente: 'malicious advertisement on a legitimate w. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): 'malicious advertisement on a legitimate website' = malvertising. As demais alternativas configuram violações g

9) B — Implementar a solução correspondente: Cenário típico: 'atacante usou senhas vaza. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credent

10) C — Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, US. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA. As demais alternativas configuram violaç

